



BOULAY



SimpleLegal

An Onit Company

SimpleLegal, Inc.

SOC 2 Type 2 Report

for the

Legal Spend and Matter Management Software System

An Independent Service Auditor's Report on the Suitability of the Design and Operating Effectiveness
of Controls Relevant to Security, Availability, Confidentiality, and Privacy

January 1, 2024 to December 31, 2024



Assurance | Tax | Advisory | Wealth Management

Minneapolis



TABLE OF CONTENTS

SECTION I. INDEPENDENT SERVICE AUDITOR'S REPORT	3
SECTION II. MANAGEMENT'S ASSERTION	7
SECTION III. DESCRIPTION OF THE LEGAL SPEND AND MATTER MANAGEMENT SOFTWARE SYSTEM	9
SECTION IV. TESTING MATRICES	25
SECTION V. OTHER INFORMATION PROVIDED BY SIMPLELEGAL	55



SECTION I

INDEPENDENT SERVICE AUDITOR'S REPORT



INDEPENDENT SERVICE AUDITOR'S REPORT

To the Management of SimpleLegal, Inc.:

Scope

We have examined SimpleLegal, Inc.'s ("SimpleLegal" or the "service organization") accompanying description of its Legal Spend and Matter Management Software System found in Section III titled "Description of the Legal Spend and Matter Management Software System" throughout the period of January 1, 2024 to December 31, 2024 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)* in AICPA, *Description Criteria* (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period of January 1, 2024 to December 31, 2024, to provide reasonable assurance that SimpleLegal's service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)* in AICPA, *Trust Services Criteria*.

SimpleLegal uses Amazon Web Services ("AWS" or the "subservice organization") to provide cloud computing and data center hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at SimpleLegal, to achieve SimpleLegal's service commitments and system requirements based on the applicable trust services criteria. The description presents SimpleLegal's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of SimpleLegal's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at SimpleLegal, to achieve SimpleLegal's service commitments and system requirements based on the applicable trust services criteria. The description presents SimpleLegal's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of SimpleLegal's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

The information included in Section V, "Other Information Provided by SimpleLegal," is presented by SimpleLegal's management to provide additional information and is not part of SimpleLegal's description of the Legal Spend and Matter Management Software System made available to user entities during the period of January 1, 2024 to December 31, 2024. Information about management's response to the testing exception has not been subjected to the procedures applied in the examination, and accordingly, we express no opinion on it.

Service Organization's Responsibilities

SimpleLegal is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that SimpleLegal's service commitments and system requirements were achieved. In Section II, SimpleLegal has provided the accompanying assertion titled "Management's Assertion" (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. SimpleLegal is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria; stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section IV, "Testing Matrices."

Opinion

In our opinion, in all material respects,

- a. the description presents SimpleLegal's Legal Spend and Matter Management Software System that was designed and implemented throughout the period of January 1, 2024 to December 31, 2024, in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period of January 1, 2024 to December 31, 2024 to provide reasonable assurance that SimpleLegal's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the subservice organization and user entities applied the complementary controls assumed in the design of SimpleLegal's controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period of January 1, 2024 to December 31, 2024 to provide reasonable assurance that SimpleLegal's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of SimpleLegal's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section IV, is intended solely for the information and use of SimpleLegal, user entities of SimpleLegal's Legal Spend and Matter Management Software System during some or all of the period of January 1, 2024 to December 31, 2024, business partners of SimpleLegal subject to risks arising from interactions with the Legal Spend and Matter Management Software System, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, the subservice organization, and other parties
- Internal control and its limitations
- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than the specified parties.



Minneapolis, Minnesota
February 19, 2025



SECTION II

MANAGEMENT'S ASSERTION

MANAGEMENT'S ASSERTION

We have prepared the accompanying description of SimpleLegal, Inc.'s ("SimpleLegal") Legal Spend and Matter Management Software System found in Section III titled "Description of the Legal Spend and Matter Management Software System" throughout the period of January 1, 2024 to December 31, 2024 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance—2022)* in AICPA, *Description Criteria* (description criteria). The description is intended to provide report users with information about the Legal Spend and Matter Management Software System that may be useful when assessing the risks arising from interactions with the system, particularly information about system controls that SimpleLegal has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus—2022)* in AICPA, *Trust Services Criteria*.

SimpleLegal uses Amazon Web Services ("AWS" or the "subservice organization") to provide cloud computing and data center hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at SimpleLegal, to achieve SimpleLegal's service commitments and system requirements based on the applicable trust services criteria. The description presents SimpleLegal's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of SimpleLegal's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at SimpleLegal, to achieve SimpleLegal's service commitments and system requirements based on the applicable trust services criteria. The description presents SimpleLegal's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of SimpleLegal's controls.

We confirm, to the best of our knowledge and belief, that:

- a. the description presents SimpleLegal's Legal Spend and Matter Management Software System that was designed and implemented throughout the period of January 1, 2024 to December 31, 2024, in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period of January 1, 2024 to December 31, 2024, to provide reasonable assurance that SimpleLegal's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organization and user entities applied the complementary controls assumed in the design of SimpleLegal's controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period of January 1, 2024 to December 31, 2024, to provide reasonable assurance that SimpleLegal's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of SimpleLegal's controls operated effectively throughout that period.



Todd Pagni
Vice President, Security and Compliance
Onit, Inc.



SECTION III

DESCRIPTION OF THE LEGAL SPEND AND MATTER MANAGEMENT SOFTWARE SYSTEM

DESCRIPTION OF THE LEGAL SPEND AND MATTER MANAGEMENT SOFTWARE SYSTEM

Company Background

SimpleLegal, Inc. ("SimpleLegal" or "the Company") is a company founded in 2013 that provides a modern, Software as a Service (SaaS)-based legal operations management solution that streamlines the way corporate legal departments manage their matters, track and interpret legal spend, and collaborate with vendors and law firms. SimpleLegal combines e-Billing, spend management, matter management, knowledge management, and vendor management, along with reporting and analytics, into one comprehensive application to optimize legal operations and the management of the entire legal department. The Company was a result of a 10-year-old consulting business where the co-founders provided data analytics services to companies spending hundreds of millions of dollars per year in legal expenses.

Industries served by SimpleLegal include Financial Services, Investment and Private Equity, Business to Business (B2B) and Business to Consumer (B2C) Software, High-Growth Tech, Public Banks, Manufacturing, Healthcare, Retail and Consumer Packaged Goods (CPG), and Educational institutions.

The Company is a subsidiary of Onit, Inc. The parent company is responsible for various control activities, as noted in this report, which should be reviewed in conjunction with the Onit SOC 2 Type 2 report for details where the SimpleLegal system relies on Onit's controls and processes. In particular, Onit is responsible for corporate governance, human resources and personnel management, employee training and development, physical security and office management, endpoint security, and workstation management.

Description of Services Provided

SimpleLegal is simple to configure, quick to deploy, and easy to use and adapt. Our solution enables customers to better support their legal operations and helps them extend these benefits to the broader organization. SimpleLegal offers the following core functions:

e-Billing & Spend Management

End-to-end control over how legal departments manage invoices, budgets, accruals, and more, so legal teams can proactively drive cost-efficiencies.

Key features include:

- Invoice management
- Automated billing guideline and discount enforcement
- AI-powered invoice reviews
- Support for Alternative Fee Arrangements (AFAs)
- Flexible workflow configurations
- Timekeeper management
- Automated accruals management
- Budget creation and management
- Dedicated, no-cost vendor portal to submit invoices (CounselGO)

Matter Management

A single place to create, manage, and collaborate on legal projects that fundamentally transforms the way legal teams – and external vendors – complete day to day tasks.

Key features include:

- Central matter repository
- Legal Requests to automate and manage legal service intake via customizable templated forms
- Customizable templates for matter creation
- Full scale document management system (DMS) with integration abilities to major DMS systems
- Confidential Matters support

- Customizable approval workflows on matters
- Track and report on unlimited custom attributes
- Budgeting tools including budget requests, refreshes, and enforcement

Vendor Management

Leverages data to objectively evaluate law firm and vendor performance, improve relationships, and simplify sourcing decisions.

Key features include:

- Intuitive portal for error-free invoice submission by law firms and vendors (CounselGO)
- Compare law firm rates and performance and refine who you work with (Vendor Surveys)
- Unified global view of vendors
- World-class, dedicated support for vendors

Knowledge Management

Improves the way legal teams create, share, and find information for quicker access to key intel to boost productivity and make better decisions.

Key features include:

- Easily find information with quick and global searches
- Identify who has worked a matter and in what capacity
- Identify and track related matters to streamline work
- Full-text search of matter documents

Reporting & Analytics

Uncover the valuable information hidden in data so legal teams have the intelligence needed to make strategic business decisions quicker and easier.

Key features include:

- Standard reports that align with legal analytics best practices and industry standards
- Easy-to-use ad hoc report builder for on-the-fly insights
- Customized reports to meet internal requirements
- Advanced reports with dynamic dashboards and presentation-ready data visuals (integration with Tableau)
- Robust dashboards and ability to drill into the data on every page
- Easily export reports for further analysis

Application Programming Interface & Integrations

Connect with the tools you rely on most to ensure a seamless workflow. SimpleLegal offers pre-built integrations as well as the flexibility for other systems to integrate via the Application Programming Interface (API).

Key features include:

- Pre-built integrations with commonly used applications, including leading finance systems, time tracking software, document and Internet protocol (IP) management solutions, and more
- Custom integrations via the Representational State Transfer (REST) API that can be easily configured with the help of internal Information Technology (IT), a third-party vendor, or the SimpleLegal Professional Services team

Professional Services

SimpleLegal can provide a complete turnkey system to meet client needs, or the Company can work in conjunction with client personnel to assist in transforming the business requirements into a functional configuration. Typically, SimpleLegal will work with a customer's project team and is involved in the aspects of project design, configuration, and deployment. System configuration is typically focused on specific business nomenclature, workflows, and matter types.

In addition, SimpleLegal partners with a variety of third-party consulting, implementation service, and data integration service providers to build robust solutions to meet customers' needs. As the need dictates, it is recommended to use one of the consulting partners that work closely with the customer to understand their requirements, and to support the design, build, and deployment of SimpleLegal. Consulting partners help to

augment the customer's internal team to drive more efficient and effective decisions across stakeholder groups. They complement SimpleLegal's technical expertise, bringing customers deep industry experience and broad solution knowledge, to help solve the problems that their business faces. SimpleLegal works hand-in-hand with the partners throughout joint implementations.

Principal Service Commitments and System Requirements

SimpleLegal designs its processes and procedures related to the Legal Spend and Matter Management Software System to meet its objectives for its services. Those objectives are based on the service commitments that SimpleLegal makes to user entities, the laws and regulations that govern the provision of the services, and the financial, operational, and compliance requirements that SimpleLegal has established for the services.

Commitments made to user entities related to security, availability, confidentiality, and privacy are communicated in Service Level Agreements (SLAs), the terms and conditions, privacy policy, and other customer agreements, as well as in the description of the service offerings provided online. These commitments are standardized and include, but are not limited to, the following:

- Security principles within the fundamental designs of the Legal Spend and Matter Management Software System that are designed to permit system users to access the information they need based on their role in the system while restricting them from accessing information not needed for their role
- Use of encryption technologies to protect customer data both at rest and in transit

Privacy Commitments

SimpleLegal's legal and compliance teams monitor best practices and changes within the industry, including changes to applicable laws and regulations:

1. A summary of the significant privacy and related security requirements common to most agreements between the service organization and its user entities and any requirements in a particular user entity's agreement that the service organization meets fully or for most user entities, Health Insurance Portability and Accountability Act (HIPAA), General Data Protection Regulation (GDPR), SOC examinations, penetration testing, etc.
2. A summary of the significant privacy and related security requirements mandated by law, regulation, an industry, or a market that are not included in user entity agreements but the service organization meets for all or most user entities California Privacy Protection Agency (CPPA).
3. The purposes, uses, and disclosures of personal information as permitted by user entity agreements and beyond those permitted by such agreements but not prohibited by such agreements and the service organization's commitments regarding the purpose, use, and disclosure of personal information that are prohibited by such agreements.
4. A statement that the information will be retained for a period no longer than necessary to fulfill the stated purposes or contractual requirements or for the period required by law or regulation, as applicable, or a statement describing other retention practices.
5. A statement that the information will be disposed of in a manner that prevents loss, theft, misuse, or unauthorized access to the information.
6. If applicable, how the service organization supports any process permitted by user entities for individuals to obtain access to their information to review, update, or correct it.
7. If applicable, a description of the process to determine that personal information is accurate and complete and how the service organization implements correction processes permitted by user entities.
8. If applicable, how inquiries, complaints, and disputes from individuals (whether directly from the individual or indirectly through user entities) regarding their personal information are handled by the service organization.
9. A statement regarding the existence of a written security program and what industry or other standards it is based on.
10. Other relevant information related to privacy practices deemed appropriate for user entities by the service organization.

SimpleLegal establishes operational requirements that support the achievement of commitments, relevant laws and regulations, and other system requirements. Such requirements are communicated in SimpleLegal’s system policies and procedures, system design documentation, and contracts with customers. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around system design, development, and operations, as well as management of internal business systems and networks. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the development and operation of SimpleLegal’s system.

Components of the System

Infrastructure

Primary infrastructure used to provide SimpleLegal’s Legal Spend and Matter Management Software System includes the following:

Hardware	Type	Purpose
AWS	Infrastructure as a Service (IaaS)	SimpleLegal hosts its service within AWS cloud service platform environment and therefore the physical infrastructure components are provisioned and managed by AWS.

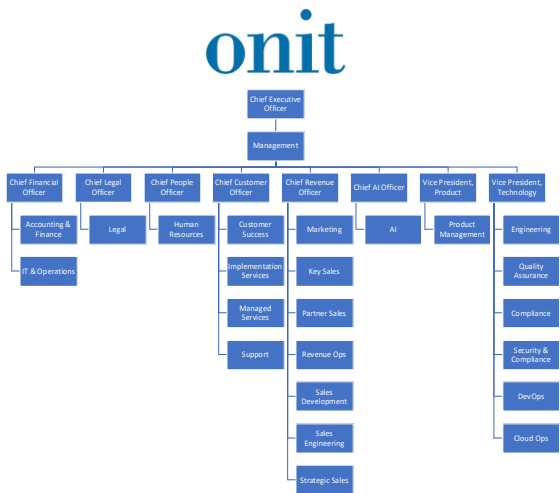
Software

Primary software used to support the Legal Spend and Matter Management Software System are noted in the table below.

Software	Operating System	Purpose
Linux	Debian 12.8	Operating System for Containers
Linux	Amazon Linux 2	Elastic Kubernetes Service (EKS) Nodes
Python	Ubuntu 18.04	Web Application
Postgres	Relational Database Services (RDS)	Database
React	Ubuntu 18.04	JavaScript Framework

People

SimpleLegal maintains a staff of approximately 600 employees across the functional areas of general administration, sales, professional services, customer success, marketing, product management, and research and development. The following organizational chart depicts the Company’s corporate structure:



Accounting & Finance

The Accounting & Finance department manages financial records, budgeting, and compliance to ensure the organization's financial health. It oversees financial reporting, risk management, and strategic planning to support business growth and stability.

IT & Operations

The IT & Operations department ensures the seamless functioning of corporate technology systems, infrastructure, and business processes to support organizational efficiency. It manages IT services, and operational workflows to drive innovation, productivity, and scalability.

Legal

The Legal department provides guidance on compliance, risk management, and regulatory matters to protect the organization's interests. It oversees contracts, disputes, and legal strategies to ensure lawful and ethical business operations.

Human Resources

The Human Resources department manages recruitment, employee relations, and organizational development to foster a productive and engaged workforce. It oversees benefits, compliance, and workplace culture to support both employee well-being and business success.

Customer Success

Provides consistent contact with established customers and ensures their satisfaction with relevant products. A segment of this team also manages work tickets submitted by customers to make changes to their application.

Implementation Services

The Implementation Services department ensures a smooth onboarding experience by configuring, integrating, and optimizing the company's solutions for clients. It manages project planning, training, and support to drive successful adoption and long-term customer satisfaction.

Managed Services

The Managed Services department provides continued client-directed enhancements (Time to Full Value), ongoing client support, and solution-specific optimization of the client-specific SaaS solutions. It proactively manages updated and new Client-specific instance deliverables and issue resolution, allowing clients to focus on continued expansion of their core business functionality.

Support

The Support department handles customer inquiries by managing support tickets, troubleshooting issues, and ensuring timely resolution to maintain a smooth SaaS experience. It also assists with additional customer requirements, providing guidance and solutions to enhance product usage and satisfaction.

Marketing

The Marketing department promotes the Company and creates customer leads by providing the necessary research to identify target customers and other audiences.

Key Sales

The Key Sales department focuses on acquiring and managing high-value clients, driving revenue growth through strategic partnerships and tailored solutions. It builds strong relationships, negotiates contracts, and collaborates with internal teams to deliver value-driven offerings that meet client needs.

Partner Sales

The Partner Sales department works with our partner community to drive revenue across various partner engagement models including reseller, co-seller, and ISV. The team also works to enable partners who implement our solutions to ensure successful customer outcomes.

Revenue Ops

The Revenue Operations department optimizes the processes, tools, and data that support the company's sales, marketing, and customer success teams to drive revenue growth. It ensures alignment across departments, streamlines workflows, and provides insights to enhance decision-making and improve overall revenue performance.

Sales Development

The Sales Development department is responsible for generating and qualifying leads to fuel the sales pipeline for the company. It identifies potential clients, engages with them through outreach, and sets up meetings to drive opportunities for the sales team.

Sales Engineering

The Sales Engineering department provides technical expertise and support throughout the sales process, helping potential clients understand how the solution meets their specific needs. It collaborates with the sales team to deliver product demonstrations, technical presentations, and customized solutions to drive successful sales conversions.

Strategic Sales

The Strategic Sales department focuses on building and nurturing relationships with key enterprise clients to drive long-term, high-value sales. It develops tailored solutions, negotiates complex deals, and collaborates with cross-functional teams to meet the unique needs of large-scale customers.

AI

The AI department develops and integrates artificial intelligence technologies into the Company's solutions to enhance automation, analytics, and decision-making capabilities. It leverages machine learning, natural language processing, large language models, and predictive analytics to create innovative features that drive value for customers and improve user experience.

Product Management

This team sets priorities for the Company through examining the current workload related to products in every department against pending or upcoming projects. This is also the department responsible for creating and planning newly developed products that have never been developed.

Engineering

The Engineering department is responsible for designing, developing, and maintaining the platform, ensuring it is scalable, secure, and high-performing. It works across software development, testing, and deployment to continuously improve the product and deliver innovative features to meet customer needs.

Quality Assurance

The Quality Assurance (QA) department ensures the product meets high standards of quality by testing and identifying bugs or issues before release. It works closely with development teams to ensure seamless functionality, reliability, and a smooth user experience across all features.

Security & Compliance

The Security & Compliance department ensures the platform is secure, resilient, and compliant with industry regulations and data protection standards. It manages risk, security protocols, and audits to safeguard customer data and maintain regulatory adherence.

DevOps

The DevOps department bridges development and IT operations to ensure efficient, reliable, and scalable deployment of the platform. It focuses on automation, continuous integration and delivery (CI/CD), and infrastructure management to enhance performance, security, and system reliability.

CloudOps

The CloudOps department ensures 24/7 monitoring of the environment's infrastructure and security. They investigate infrastructure security incidents and escalate issues as needed for further support.

Data

Data processed by the system is documented in the *Description of Services Provided* section of this report. The data flowing through SimpleLegal's infrastructure is restricted to authorized individuals requiring such access, including the Company's customer base. Logical access controls described below ensure access is restricted to authorized individuals based on job functions.

The following table describes the information included as part of the Legal Spend and Matter Management Software System:

Client Data	Reporting
Clients choose the types of data they collect and input it into the Legal Spend and Matter Management Software System. This could include names, business e-mails, addresses and contact information, and other business-related information.	- Standard reports vary based on the specific SimpleLegal applications and/or specific use case of a client. - Every client has the ability to export data and create their own dashboard reports.

Policies and Procedures

SimpleLegal policies and procedures are maintained and updated at least annually. SimpleLegal employees are required to acknowledge their understanding of the policies and procedures upon hire.

Relevant Aspects of the Control Environment, Risk Assessment Process, Information and Communication, and Monitoring

Control Environment

Management's Philosophy

The Company's organizational structure provides the framework within which its activities for achieving entity-wide objectives are completed and analyzed. The Company is organized in a manner which defines key areas of authority while maintaining adequate separation of duties.

Integrity and Ethical Values

Integrity and high ethical standards are qualities essential to the Company's business and are viewed as fundamental standards of behavior for the employees. The effectiveness of internal controls cannot rise above the integrity and ethical values of the people who create, administer, and monitor them. The Company established programs and policies designed to communicate and reinforce the integrity and ethical standards of the Company. Any employee found to have violated the ethics policy may be subject to disciplinary action, up to and including termination.

Specific control activities that the service organization has implemented in this area are described below:

- Formally, documented organizational policy statements and codes of conduct communicate entity values and behavioral standards to personnel
- Policies and procedures require employees sign an acknowledgment form indicating they have been given access to the employee manual and understand their responsibility for adhering to the policies and procedures contained within the manual
- A confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties is a component of the employee handbook
- Background checks are performed for employees as a component of the hiring process

Commitment to Competence

The Company defines competence as the knowledge and skills necessary to accomplish tasks that define an employee's roles and responsibilities. The Company seeks only high-quality staff with significant experience, education, and understanding of working in a team environment. Management analyzes the knowledge and skills required to complete given tasks and confirms the individuals can complete the tasks through interviewing, reference and background checks, as well as other investigative means.

Specific control activities that the service organization has implemented in this area are described below:

- Management has considered the competence levels for jobs and translated required skills and knowledge levels into written position requirements.
- Training is provided to maintain the skill level of personnel in certain positions.

Operating Style

The Company's organizational structure provides the framework within which its activities for achieving entity-wide objectives are completed and analyzed. The Company is organized in a manner which defines key areas of authority while maintaining adequate separation of duties.

Specific control activities that the service organization has implemented in this area are described below:

- Management is briefed on regulatory and industry changes affecting the services provided.
- Executive management meetings are held to discuss major initiatives and issues that affect the business.

Organizational Structure and Assignment of Authority and Responsibility

The Company is organized in a manner that fosters collaboration and communication with management and staff. This organization allows for proper segregation of duties while providing a high level of service to the clients.

Specific control activities that the service organization has implemented in this area are described below:

- Organizational charts are in place to communicate key areas of authority and responsibility.
- Organizational charts are communicated to employees and updated as needed.

Security Management

SimpleLegal's Vice President, Compliance and Security is designated as the Security Officer, and general implementation and management of security issues in the system are delegated to the Security and DevOps teams. The Security Officer is responsible for developing, maintaining, and enforcing SimpleLegal's information security policies with input from other relevant business units. The information security policies are reviewed as needed by the Security Officer.

As the Security and DevOps teams maintain security, they also monitor known incidents and patches as well as results from recent vulnerability assessments and address necessary changes to the policies and procedures. Such changes can include a reclassification of data, a reassessment of risk, changes in incident response plans, and a verification of responsibilities for authorizing and monitoring accesses. Changes are reviewed and communicated during weekly DevOps team meetings or through system alerts.

All SimpleLegal employees and contractors are required to attend information security awareness training on an annual basis to ensure that personnel are knowledgeable of risks and controls around cybersecurity and data protection.

Personnel Security

New positions that are posted at SimpleLegal have clearly defined job descriptions and outline the technical and educational requirements the Company is seeking in prospective candidates. Employment at SimpleLegal is contingent upon the successful completion of a background screening, to the extent permitted by local laws. Once employed, personnel are subject to SimpleLegal's procedures around information security. A provisioning ticket is submitted to the IT team requesting that newly hired personnel obtain the system access necessary to perform their job. Access is granted based on the principle of least privilege. User access is reviewed quarterly for appropriateness.

Physical Security and Environmental Controls

The in-scope systems and infrastructure that support SimpleLegal are hosted in the cloud by AWS (see *Complementary Subservice Organization Controls* section below). SimpleLegal does not have a physical office space as all employees work remotely. Onit's main office, which houses personnel responsible for the SimpleLegal system, is located in Houston, Texas, with additional offices in Austin, Texas and Pune, India. The offices have the following security protocols in place:

- Key fobs are required to access the main building entrance and office
- Video surveillance cameras that provide 24/7 streaming, recording and motion detection
- Alarm systems that automatically connect to security contractors
- Shredders to securely dispose of hard-copy documents

Logical Security

SimpleLegal has policies and procedures that outline information technology security standards. These documents are available for review by all employees and contractors through SharePoint. SimpleLegal uses role-based security architecture and requires users of the system to be identified and authenticated prior to the use of any system resources. Resources are protected through the use of native system security and add-on software products that identify and authenticate users and validate access requests against the users' authorized roles in access control lists.

Accountability

Individual users are responsible for ensuring that others do not access data or information from their systems. Users need to take great care in protecting their usernames and passwords and this information is never to be loaned or given to other members of the Company or outside individuals. Disclosing this information could lead to vulnerabilities of the system as well as to the data and information contained on the system.

Access to resources and data are granted to individuals based on their job responsibilities. New user accounts are established only upon receipt of properly authorized requests. The security administrator is responsible for ensuring adherence to the security policy which addresses logical access control procedures.

Individual access capabilities are removed within 48 hours by IT or data owners upon the notification of termination of employment, change of responsibilities, or termination of a contract with a client that uses the system. System security access levels are reviewed quarterly by IT and data owners to ensure individual access rights are appropriate based on job information.

Change Management

SimpleLegal maintains a documented Change Management Policy to guide personnel in documenting and implementing application and infrastructure changes. Change control procedures include change request and initiation processes, documentation requirements, development practices, quality assurance testing requirements, and required approval procedures.

A ticketing system is utilized to document the change control procedures for changes in the application and implementation of new changes. Quality assurance testing (QAT) and user acceptance testing (UAT) results are documented and maintained with the associated change request. Development and testing are performed in an environment that is logically separated from the production environment. Management approves changes prior to migration to the production environment and documents those approvals within the ticketing system.

Version control software is utilized to maintain source code versions and migrate source code through the development process to the production environment. The version control software maintains a history of code changes to support rollback capabilities and tracks changes to developers.

Data Communications

The Company uses a variety of methods for communication to ensure that significant events and issues are sent in a timely manner and that staff understand their role and responsibility over service and controls. These methods include the following:

- New hire training
- Ongoing training
- Policy and process updates
- Departmental meetings summarizing events and changes
- Use of e-mail systems

System Monitoring

SimpleLegal performs system monitoring activities to continuously assess the quality of internal control over time and ensure that any corrective actions are completed in a timely manner. Examples of system monitoring processes in place include:

- Firewalls – Firewalls protecting the internal network from the public network are implemented, configured, and managed by the SimpleLegal administration staff. Firewalls utilize access rules to grant or deny access to internal resources.
- Vulnerability Scanning – Scanning is performed by a third-party vendor on a monthly basis in accordance with SimpleLegal policy. The third-party vendor uses industry standard scanning technologies and a formal methodology specified by Open Web Application Security Project (OWASP). These technologies are customized to test the organization's infrastructure and software in an efficient manner while minimizing the potential risks associated with active scanning. Retests and on-demand scans are performed on an as needed basis.
- Intrusion Detection Systems – Provide continuous monitoring of cybersecurity threats.
- Penetration Testing – SimpleLegal hires third-party security firms that use an accepted industry standard penetration testing methodology. The third-party vendor's approach begins with a vulnerability analysis of the target system to determine what vulnerabilities exist on the system that can be exploited via a penetration test, simulating a disgruntled/disaffected insider or an attacker that has obtained internal access to the network. Once vulnerabilities are identified, the third-party vendor attempts to exploit the vulnerabilities to determine whether unauthorized access or other malicious activity is possible. Penetration testing includes application layer testing as well as testing of controls and processes around the applications.
- Patch Management – SimpleLegal has implemented a patch management process to ensure infrastructure systems are patched in accordance with vendor recommended operating system patches. SimpleLegal system owners review proposed operating system patches to determine whether the patches are applied. SimpleLegal systems are responsible for determining the risk of applying or not applying patches based upon the security and availability impact of those systems and any critical applications hosted on them. SimpleLegal staff validate that the patches have been installed and, if applicable, that reboots have been completed.

Problem Management

Security incidents are reported to the Security and Compliance teams through an internal ticketing application. Issues are triaged and tracked using a ticketing system and monitored until resolved.

Data Backup and Recovery

Customer data is backed up daily and monitored by operations personnel for completion and exceptions. In the event of an exception, operations personnel perform troubleshooting to identify the root cause and then re-run the backup job immediately or as part of the next scheduled backup job depending on customer indicated preferences within the documented work instructions.

Backup data is stored remotely where SimpleLegal personnel have no physical access. The backup infrastructure resides on private networks logically segmented from other networks.

Incident Response

Incident response policies and procedures are in place to guide personnel in reporting and responding to information technology incidents. Procedures exist to identify, report, and act upon system security breaches and other incidents.

Availability

SimpleLegal monitors the capacity utilization of its cloud computing infrastructure within AWS to ensure that service delivery meets service level agreements. SimpleLegal evaluates the need for additional infrastructure capacity in response to growth of existing customers and/or the addition of new customers. Infrastructure capacity monitoring includes, but is not limited to, the following:

- CPU usage
- Disk storage
- Network bandwidth
- System processing throughput

Confidentiality

SimpleLegal identifies its sources of confidential information and maintains controls to safeguard this information from unauthorized access and disclosure. Confidential information that is collected by SimpleLegal is retained in accordance with SimpleLegal's record retention policies.

The members of the Company are obligated to protect confidential data in their control. The Confidentiality Policy discusses the methods of protecting such information and procedures to safeguard the data during transmission.

Privacy

As a data processor, SimpleLegal has controls in place to ensure PII data is encrypted at rest and in transit. The Company has also implemented a consent management framework in its infrastructure to comply with data subject requests.

SimpleLegal maintains a Privacy Policy that is incorporated into the Company's terms of service. The Privacy Policy outlines how and why the Company collects personal information, how that information is stored and how long, as well as matters related to consent and control over personal information. The Company maintains safeguards to protect personal information and is committed to ensuring compliance with relevant data privacy laws.

Information Flow from Senior Management to SimpleLegal Staff

SimpleLegal has implemented various methods of communication to help ensure that employees understand their individual roles and responsibilities for transaction processing, adherence to controls, and communication of significant events in a timely manner. Employees sign an Employee Acknowledgement Form regarding the SimpleLegal Employee Handbook stating that they have received and read the manual. Security of the logical security of systems is reinforced by training and through awareness programs. The communication system between senior management and SimpleLegal staff includes the use of the office email system and weekly meetings. Periodic department meetings between each manager and their staff are also held to discuss new company policies and procedures and other business issues. Communication is encouraged at different levels to promote the operating efficiency of SimpleLegal.

Human Resources Security

SimpleLegal observes HR policies, procedures, and guidelines within its Employee Handbook. Management updates these policies as appropriate. SimpleLegal managers observe these policies, procedures, and guidelines as well as applicable federal and state laws as they relate to recruitment, selection, and hiring of employees.

The primary objectives of personnel recruitment are to place the most qualified person available in the vacant position and to reduce operating costs by minimizing turnover. HR coordinates the performance of background checks with third-party specialists.

Newly hired employees undergo security awareness training to introduce the employee to confidentiality and security requirements. SimpleLegal has implemented various methods of communication to help ensure that employees understand their individual roles and responsibilities over user data and controls, and that significant events are communicated in a timely manner. The Employee Handbook covering SimpleLegal policies is communicated to each employee. Employees sign an acknowledgement form that they have received and will comply with SimpleLegal policies.

Management collects the Company property and assets (e.g., Company credit cards, keys, computer, etc.) from terminated employees. The Company proprietary files are secured, and access to electronic resources (e.g., telephone, network, computer, e-mail, etc.) is terminated.

Risk Assessment Process

SimpleLegal recognizes that risk management is a critical component of its operations and contributes to ensuring customer data is properly protected. SimpleLegal incorporates risk management throughout its business processes and across the organization. The foundation of this process is management's knowledge of its operations, its close working relationship with its customers and vendors, and its understanding of the space in which it operates.

SimpleLegal conducts a risk assessment at least quarterly. The system risk assessment template enables SimpleLegal to describe their cause and potential impact and outline mitigation steps to reduce the likelihood and impact.

Integration with Risk Assessment

SimpleLegal addresses risks through the implementation of suitably designed controls to provide reasonable assurance that the criteria are met. Because each system and the environment in which it operates is unique, the combination of risks to meeting the criteria and the controls necessary to address the risks will be unique. As part of the design and operation of the system, SimpleLegal's management identifies the specific risks that the criteria will not be met and the controls necessary to address those risks.

Information and Communication Systems

All employees and contractors are required to acknowledge their understanding of information security policies, standards, and procedures, as well as confidentiality agreements. This acknowledgement is both within employment agreements/contracts as well as within SharePoint.

In addition, internal meetings are held for specific problem resolution and general information dissemination. Email distribution lists are also maintained to ensure job executions are smooth and knowledge of the processes is clear and up to date.

Monitoring Controls

Company management performs monitoring activities as part of normal business operations to assess the quality of the internal control environment. Management performs regular reviews of tasks assigned to their teams. Monitoring activities are used to initiate corrective action through team meetings, client conference calls, and informal notifications. Corrective actions are taken as required to correct deviations from Company policy and procedures. Tasks that are not addressed in a timely manner are escalated and resolved.

Ongoing Monitoring

SimpleLegal utilizes a suite of monitoring tools to provide proactive incident identification and response services. The DevOps and CloudOps teams regularly monitor the network. Overall health and capacity planning are monitored to ensure the system will meet clients' needs. The monitoring applications generate alerts when predefined thresholds are exceeded on the monitored devices. CloudOps, Security, and Compliance monitor security access violations, including server logs and reports.

Monitoring policies and procedures are utilized for addressing issues relating to outages of critical services or other issues needing immediate action. These procedures vary based on the defined severity level of the problem. Company engineers use several monitoring tools to identify and provide alerts.

Reporting Deficiencies

SimpleLegal's risk and issues register is utilized to document and track the results of ongoing monitoring procedures. Escalation procedures are maintained for responding and notifying management of any identified risks and/or issues. Issues receiving a high rating are responded to immediately. Corrective actions are documented and tracked within the risk and issues register. Regular risk meetings are held for management to review reported deficiencies and corrective actions.

Control Objectives and Related Controls

SimpleLegal's control objectives and description of related controls are included in Section IV, "Testing Matrices." Although the control objectives and related controls are included in Section IV, they are an integral part of the description of the Legal Spend and Matter Management Software System.

Complementary User Entity Controls (CUECs)

SimpleLegal's controls cover only a portion of overall internal controls for each user entity of the contract lifecycle management system. It is not feasible for the service commitments, system requirements, and applicable criteria related to the system to be achieved solely by SimpleLegal. Therefore, each user entity's internal controls should be evaluated in conjunction with SimpleLegal's controls, considering the related CUECs identified for the specific criterion. For user entities to rely on the controls reported herein, each user entity must evaluate its own internal controls to determine whether the identified CUECs have been implemented and are operating effectively.

The user entity controls presented should not be regarded as a comprehensive list of all controls that should be employed by user entities.

- User entities are responsible for controls to input complete and accurate information and comply with the operating instructions of the Company's products and applications.
- User entities are responsible for controls to comply with the operating instructions of the Company's products and applications.
- User entities are responsible for controls to communicate with the Company regarding failures, incidents, concerns, and other matters when complying with the operating instructions of the Company's products and applications.
- User entities are responsible for informing the Company of any regulatory issues that may affect the services provided by the Company.
- User entities are responsible for risks related to the use of IT and access to information when granting access to the services provided by the Company.
- User entities are responsible for controls to notify the Company in a timely manner when changes are made to technical, billing, or administrative contact information.
- User entities are responsible for controls to provide reasonable assurance that output reports are reviewed by appropriate individuals for completeness and accuracy.
- User entities are responsible for controls to ensure that user entities adopt strong operating system and application password management procedures, including using passwords that cannot be easily compromised and require changing on a regular basis.
- User entities are responsible for controls to ensure the confidentiality of any user identifications (IDs) and passwords assigned.
- User entities are responsible for procedures to define developing, maintaining, and testing their own business continuity plans.
- User entities are responsible for controls to provide reasonable assurance of the transmission and receipt of information not provided by the Company.
- User entities are responsible for controls to immediately notify the Company of any actual or suspected information security breaches, including compromised user accounts.
- User entities are responsible for approving the telecommunications infrastructure controls between themselves and the Company.
- User entities are responsible for controls to ensure compliance with contractual requirements.
- User entities are responsible for controls for the supervision, management, and control of the use of the Company's applications by its personnel.
- User entities are responsible for controls to maintain their own systems of recordkeeping.
- User entities are responsible for controls to dictate the use of encryption for all interactions outside the boundaries of SimpleLegal's Legal Spend and Matter Management Software System.
- User entities are responsible for providing notice to data subjects about its privacy practices to meet the entity's objectives related to privacy.

- User entities are responsible for communicating choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice.
- User entities are responsible for collecting data consistent with the entity's objectives related to privacy.
- User entities are responsible for providing data subjects information requiring explicit consent.
- User entities are responsible for limiting the use of personal information to the purposes identified in the entity's objectives related to privacy.
- User entities are responsible for granting identified and authenticated data subjects the ability to access their stored personal information for review and, upon request, provides physical or electronic copies of that information to data subjects to meet the entity's objectives related to privacy. If access is denied, the entity is responsible for providing a reason for the denial.
- User entities are responsible for correcting, amending, or appending personal information based on information provided by data subjects and communicating such information to third parties, as committed, or required, to meet the entity's objectives related to privacy. If changes are denied, the entity is responsible for communicating the reason for the denial.
- User entities are responsible for obtaining explicit consent of data subjects when disclosing personal information to third parties.
- User entities are responsible for creating and retaining a complete, accurate, and timely record of authorized disclosures of personal information.
- User entities are responsible for providing notification of breaches and incidents to affected data subjects, regulators, and others to meet the entity's objectives related to privacy.
- User entities are responsible for providing data subjects with an accounting of the personal information held and disclosure of the data subjects' personal information, upon the data subjects' request.
- User entities are responsible for collecting and maintaining accurate, up-to-date, complete, and relevant personal information.

Complementary Subservice Organization Controls (CSOCs)

SimpleLegal leverages AWS for cloud computing and data center hosting services. SimpleLegal's services are designed with the assumption that certain controls will be implemented at AWS. Such controls are called complementary subservice organization controls. It is not feasible for the service commitments, system requirements, and applicable criteria related to the contract lifecycle management system to be achieved solely by SimpleLegal. Therefore, each user entity's internal controls must be evaluated in conjunction with SimpleLegal's controls, considering the related CSOCs expected to be implemented at the subservice organizations, as described below.

Criteria	Control Activity
CC6.4 CC7.2	• Recovery key materials used for disaster recovery processes by Key Management Service (KMS) are physically secured offline so that no single AWS employee can gain access to the key material. • Access attempts to recovery key materials are reviewed by authorized operators on a cadence defined in team documentation. • Physical access to data centers is approved by an authorized individual. • Physical access is revoked within 24 hours of the employee or vendor record being deactivated. • Physical access to data centers is reviewed on a quarterly basis by appropriate personnel. • Closed circuit television cameras (CCTV) are used to monitor server locations in data centers. Images are retained for 90 days, unless limited by legal or contractual obligations. • Access to server locations are managed by electronic access control devices. • Electronic intrusion detection systems are installed within data server locations to monitor, detect, and automatically alert appropriate personnel of security incidents.

A1.2	• Amazon-owned data centers are protected by fire detection and suppression systems. • Amazon-owned data centers are air conditioned to maintain appropriate atmospheric conditions. Personnel and systems monitor and control air temperature and humidity at appropriate levels. • Uninterruptible Power Supply (UPS) units provide backup power in the event of an electrical failure in Amazon-owned data centers and third-party colocation sites where Amazon maintains the UPS units. • Amazon-owned data centers have generators to provide backup power in case of electrical failure. • Contracts are in place with third-party colocation service providers which include provisions to provide fire suppression systems, air conditioning to maintain appropriate atmospheric conditions, UPS units (unless maintained by Amazon), and redundant power supplies. Contracts also include provisions requiring communication of incidents or events that impact Amazon assets and/or customers to AWS. • AWS performs periodic reviews of colocation service providers to validate adherence with AWS security and operational standards. • Monitoring and alarming are configured by Service Owners to identify and notify operational and management personnel of incidents when early warning thresholds are crossed on key operational metrics. • Incidents are logged within a ticketing system, assigned a severity rating and tracked to resolution. • Critical AWS system components are replicated across multiple Availability Zones and backups are maintained. • Backups of critical AWS system components are monitored for successful replication across multiple Availability Zones.
------	--

SimpleLegal receives and reviews the AWS SOC 2 Type 2 report annually. In addition, through its operational activities, SimpleLegal monitors the services performed by AWS to determine whether operations and controls expected to be implemented at the subservice organization are functioning effectively. SimpleLegal also has communication with the subservice organization to monitor compliance with the service agreements, stay up to date on planned changes at the hosting facilities, and communicate any issues or concerns to AWS.

System Incidents

There were no identified system incidents that (a) were the result of controls that were not suitably designed or operating effectively to achieve one or more of the service commitments and system requirements or (b) otherwise resulted in a significant failure to the achievement of one or more of those service commitments and system requirements during the period of January 1, 2024 to December 31, 2024.

Trust Services Criteria Not Applicable

The below Privacy criteria are not applicable as SimpleLegal is a data processor:

- P1.1: The entity provides notice to data subjects about its privacy practices to meet the entity's objectives related to privacy. The notice is updated and communicated to data subjects in a timely manner for changes to the entity's privacy practices, including changes in the use of personal information, to meet the entity's objectives related to privacy.
- P2.1: The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice. Explicit consent for the collection, use, retention, disclosure, and disposal of personal information is obtained from data subjects or other authorized persons, if required. Such consent is obtained only for the intended purpose of the information to meet the entity's objectives related to privacy. The entity's basis for determining implicit consent for the collection, use, retention, disclosure, and disposal of personal information is documented.
- P3.2: For information requiring explicit consent, the entity communicates the need for such consent as well as the consequences of a failure to provide consent for the request for personal information and obtains the consent prior to the collection of the information to meet the entity's objectives related to privacy.

Except for the above, all criteria within the security, availability, confidentiality, and privacy categories were applicable to the Legal Spend and Matter Management Software System.

Significant Changes to the System

There were no changes that are likely to affect report users' understanding of how the system was used to provide services during the period of January 1, 2024 to December 31, 2024.



SECTION IV

TESTING MATRICES

SECURITY

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Control Environment			
CC1.1 COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.			
CC1.1.1	SimpleLegal has established a Code of Conduct policy that is acknowledged by all new employees and full-time contractors upon hire. This policy outlines expectations the Company has set related to ethics and standards of conduct. Additionally, this policy outlines processes that management has established to evaluate adherence to standards of conduct and address deviations in a timely manner.	Inspected the Employee Handbook to verify whether it outlined expectations around ethical conduct for employees and contractors, as well as disciplinary actions if the policy is violated. For all new hires during the period, inspected the signed handbook to verify whether each individual had acknowledged and accepted the Code of Conduct policy.	No exceptions noted.
CC1.2 COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.			
CC1.2.1	SimpleLegal is a subsidiary of Onit, whose leaders have relevant skills and industry expertise that enable them to provide independent oversight over management.	Inspected Onit's website to verify whether Onit's executive leadership team consists of individuals with relevant skills and industry expertise that enables them to provide independent oversight over management.	No exceptions noted.
CC1.2.2	SimpleLegal meets with the Onit Board of Directors on at least a quarterly basis to discuss Company performance, strategic objectives, and information security matters.	For a selection of quarters during the period, inspected the Board of Directors meeting invitation and notes to verify whether the Board of Directors met on a quarterly basis to discuss Company performance, strategic objectives, and information security matters.	No exceptions noted.
CC1.3 COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.			
CC1.3.1	SimpleLegal maintains an updated organizational chart that establishes structure, reporting lines, and delegation of authority and responsibility across the Company.	Inspected the organizational chart to verify whether it established the structure, reporting lines, and delegation of authority and responsibility across the Company.	No exceptions noted.
CC1.3.2	SimpleLegal's executive leadership meets on a monthly basis to discuss operations, issues relating to internal controls, and delivery on key performance metrics.	For a selection of months, inspected executive leadership meeting invitations and agendas to verify whether they included discussions regarding operations, issues relating to internal controls, and delivery on key performance metrics.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC1.3.3	SimpleLegal has an assigned security team that is responsible for the design, implementation, and oversight of the Company's security policies and procedures. The security team communicates important information security events to management and the Board of Directors in a timely manner.	Inspected the Incident Reporting and Response Policy to verify whether a security team had been formally designated, along with clearly defined roles and responsibilities. For a selection of quarters during the period, inspected the Board of Directors meeting invitation and notes to verify whether a member of the security team was present to communicate important information security events to management and the Board of Directors.	No exceptions noted.
CC1.4 COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.			
CC1.4.1	All positions have a detailed job description that lists qualifications, such as required skills and experience, which candidates must meet in order to be hired by SimpleLegal.	Inspected the Onit careers website to verify whether open positions had job descriptions that listed the qualifications Onit was seeking for the role.	No exceptions noted.
CC1.4.2	SimpleLegal performs background checks on new employees prior to hire, as permitted by local laws. The results are reviewed by Human Resources and appropriate action is taken if deemed necessary.	For all new hires during the period, inspected the completed background check report to verify whether each individual had a comprehensive background check performed prior to their starting date, as permitted by local laws.	No exceptions noted.
CC1.4.3	Executive management holds monthly meetings that include analyzing the competency of its staff against the required business objectives and forecasted growth to determine whether additional resources are necessary.	For a selection of months, inspected executive leadership meeting invitations and agendas to verify whether they included discussions regarding human resources.	No exceptions noted.
CC1.5 COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.			
CC1.5.1	SimpleLegal maintains formalized performance expectations for each position and uses these expectations as a basis for evaluating the performance of each of its employees. These performance evaluations, which incorporate internal control responsibilities, are completed on an annual basis.	For a selection of active personnel during the period, inspected completed performance evaluations to verify whether each individual received a formalized performance evaluation during the period which incorporated internal control responsibilities.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Communication and Information			
CC2.1 COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
CC2.1.1	SimpleLegal's mission-critical systems and sensitive information are identified as part of their asset inventory, which includes capturing internal and external sources of data.	Inspected the AWS dashboard and Jamf inventory report to verify whether SimpleLegal had identified its mission-critical systems and sources of sensitive information.	No exceptions noted.
CC2.1.2	SimpleLegal maintains an updated cloud architecture diagram outlining how data is processed and secured within AWS.	Inspected SimpleLegal's cloud architecture diagrams to verify whether they provided a comprehensive illustration of the AWS architecture and how data is processed and secured.	No exceptions noted.
CC2.2 COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.			
CC2.2.1	SimpleLegal maintains updated policies and procedures that enable all personnel to understand and carry out their internal control responsibilities, including ensuring confidentiality, integrity, and availability of all systems and data. These policies and procedures are accessible to all personnel and are acknowledged upon hire.	Inspected the collection of organizational policies and procedures to verify whether they outlined roles and responsibilities around internal control performance. Inspected the internal shared folder to verify whether up-to-date policies and procedures were available to all SimpleLegal personnel. For all new hires during the period, inspected the signed handbook to verify whether each individual had acknowledged and accepted the organizational policies and procedures.	No exceptions noted.
CC2.2.2	SimpleLegal employees are required to complete information security awareness training upon hire and on at least an annual basis thereafter.	For all new hires during the period, inspected security training completion certificates to verify whether training was completed upon hire. For a selection of active personnel during the period, inspected security training completion certificates to verify whether training was completed annually.	No exceptions noted.
CC2.2.3	SimpleLegal provides a process for employees and contractors to report security failures, incidents and concerns, and other complaints to management.	Inspected the Incident Reporting and Response Policy to verify whether it provided a process for employees and contractors to report security failures, incidents and concerns, and other complaints to management.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC2.3 COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.			
CC2.3.1	SimpleLegal enables inbound communications from customers and other stakeholders by maintaining contact information on their website for general inquiries, customer support, partnerships, and public relations.	Inspected the SimpleLegal website to verify whether contact information was available for general inquiries, customer support, partnerships, and public relations. Inspected a test submission to the SimpleLegal support channel to verify whether it was actively monitored and managed by the support team.	No exceptions noted.
CC2.3.2	Objective descriptions of SimpleLegal's system and its boundaries are available to authorized external users and customers.	Inspected the Company website to verify whether objective descriptions of SimpleLegal's system and its boundaries were available to authorized external users and customers.	No exceptions noted.
CC2.3.3	SimpleLegal maintains an updated Terms of Service and Service Level Agreement on its website that communicates the Company's commitment to security, availability, and confidentiality to external users.	Inspected the SimpleLegal Terms of Service and Service Level Agreement to verify whether it demonstrated the Company's security, availability, and confidentiality commitments.	No exceptions noted.
Risk Assessment			
CC3.1 COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
CC3.1.1	SimpleLegal maintains a risk management program that describes the processes the Company has in place to identify new business and technical risks and how those risks are mitigated.	Inspected the risk management policy to verify whether it was up-to-date and documented requirements and guidelines to performing a comprehensive risk assessment.	No exceptions noted.
CC3.1.2	On a quarterly basis, SimpleLegal conducts an assessment on the risks related to data security, data integrity, scalability, and privacy.	For a selection of quarters, inspected the completed risk assessment to verify whether it incorporated risks and controls related to data security, data integrity, scalability, and privacy.	No exceptions noted.
CC3.2 COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.			
CC3.2.1	On a quarterly basis, SimpleLegal performs a risk assessment, which includes the identification of relevant internal and external threats, an analysis of the significance of the risks associated with those threats, a determination of appropriate risk mitigation strategies, and the development or modification of controls consistent with the risk mitigation strategy.	For a selection of quarters, inspected the completed risk assessment to verify whether it incorporated a comprehensive threat analysis, including probability and impact ratings, mitigating controls, and any action plans to further mitigate risks to an acceptable level.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC3.3 COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.			
CC3.3.1	As part of the risk assessment process, management considers various types of fraud exposure, the probability and impact of the event occurring, the controls in place to mitigate the risk of fraud, and what, if any, additional mitigation measures are necessary.	For a selection of quarters, inspected the completed risk assessment to verify whether it incorporated fraud considerations, including probability and impact ratings, mitigating controls and any action plans to further mitigate the risk of fraud to an acceptable level.	No exceptions noted.
CC3.4 COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.			
CC3.4.1	As part of the risk assessment process, management identifies and assesses changes that could significantly impact the system of internal control. The assessment includes evaluating changes in data security, data integrity, scalability, and privacy.	For a selection of quarters, inspected the completed risk assessment to verify whether it included an evaluation of changes pertaining to data security, data integrity, scalability, and privacy.	No exceptions noted.
Monitoring Activities			
CC4.1 COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			
CC4.1.1	SimpleLegal conducts ongoing monitoring over internal controls to ensure they are adequately designed and operating effectively, in accordance with baseline requirements. These evaluations are conducted by knowledgeable personnel, integrate with business processes, consider changes in business processes, and vary in frequency based on associated risks.	Inspected the results of the below monitoring tools and activities to verify whether they were implemented and monitored by management: • Web application penetration testing • Vulnerability scanning • Intrusion detection systems • Phishing campaigns	No exceptions noted.
CC4.1.2	SimpleLegal engages a qualified third-party security firm to conduct penetration tests of its web application at least annually. Results are reviewed by management and high priority findings are remediated in a timely manner.	Inspected the web application penetration test results to verify whether it was completed by a qualified third-party security firm. For all high severity findings, inspected the letter of attestation to verify whether SimpleLegal remediated the findings in a timely manner.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC4.1.3	SimpleLegal has implemented a vulnerability management program to detect and remediate system vulnerabilities in software packages used in the Company's infrastructure. System patching is performed on a periodic basis by the infrastructure team for proper vulnerability mitigation.	For a selection of months during the period, inspected the Probely vulnerability scanning reports to verify whether SimpleLegal had implemented a vulnerability management program to detect and remediate system vulnerabilities in software packages. Per inspection of the Probely vulnerability scanning reports, noted that there were no vulnerabilities that required patching. Therefore, further testing was not applicable.	No exceptions noted.
CC4.1.4	SimpleLegal uses intrusion detection systems that continuously monitor for malicious activity and unauthorized behavior related to AWS accounts, workloads, and data.	Inspected the GuardDuty and CrowdStrike intrusion detection systems to verify whether they were implemented to monitor for malicious activity and unauthorized behavior related to AWS accounts, workloads, and data.	No exceptions noted.
CC4.1.5	SimpleLegal has established a formalized phishing prevention and monitoring campaign to evaluate employee response to potential social engineering attacks. Personnel who fail the phishing simulations are subject to additional training.	Inspected the Mimecast security platform to verify whether it was used to conduct phishing testing on SimpleLegal employees and contractors during the period. Inspected the post-failure training emails to verify whether additional security training was provided to personnel who failed phishing tests during the period.	No exceptions noted.
CC4.2 COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and board of directors, as appropriate.			
CC4.2.1	Management assesses the results of ongoing and separate evaluations. Deficiencies are communicated to relevant parties for corrective action, and management tracks whether the deficiencies are remediated in a timely manner.	For all high severity findings from the penetration test, inspected the letter of attestation to verify whether SimpleLegal remediated the findings in a timely manner. Inspected the post-failure training emails to verify whether additional security training was provided to personnel who failed phishing tests during the period. Per inspection of the Probely vulnerability scanning reports, noted that there were no vulnerabilities that required patching. Therefore, further testing was not applicable.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Control Activities			
CC5.1 COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			
CC5.1.1	As part of the risk assessment process, management ensures that adequate controls are in place to mitigate the identified risks to an acceptable level. Considerations in the identification and implementation of control activities include entity-specific factors, relevant business processes, incorporating a mix of control activity types (manual, automated, preventive, detective), and segregation of duties.	For a selection of quarters, inspected the completed risk assessment and the organizational policies and procedures to verify whether they included a suite of internal controls that were designed to mitigate the identified risks to an acceptable level. For a selection of quarters, inspected the completed risk assessment and the organizational policies and procedures to verify whether they incorporated a mix of control activity types, such as manual, automated, preventive, and detective controls, including segregation of duties.	No exceptions noted.
CC5.2 COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.			
CC5.2.1	SimpleLegal maintains a suite of Information Technology General Controls (ITGCs) to support the achievement of objectives. These ITGCs are identified as part of the annual risk assessment completed by management and cover areas such as technology infrastructure and security management as well as technology acquisition, development, and maintenance.	For a selection of quarters, inspected the completed risk assessment and the organizational policies and procedures to verify whether a comprehensive suite of ITGCs was implemented.	No exceptions noted.
CC5.3 COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.			
CC5.3.1	SimpleLegal maintains updated policies and procedures that incorporate control activities across the organization. These policies and procedures establish requirements pertaining to timely performance of controls, taking corrective action on control deficiencies, and ensuring that competent personnel are accountable for control execution.	Inspected the organizational policies and procedures to determine whether they incorporated a comprehensive suite of internal controls, outlined roles and responsibilities for control performance, and established requirements related to the timely remediation of control deficiencies.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Logical and Physical Access Controls			
CC6.1: The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			
CC6.1.1	SimpleLegal maintains an updated inventory of information assets within the organization.	Inspected SimpleLegal's information asset inventory to verify whether a comprehensive inventory of information assets was documented.	No exceptions noted.
CC6.1.2	Access to SimpleLegal's infrastructure and sensitive systems/applications requires complex passwords and multi-factor authentication (MFA).	Inspected the OneLogin configuration settings to verify whether complex passwords and MFA were required to access SimpleLegal's infrastructure and sensitive systems/applications.	No exceptions noted.
CC6.1.3	SimpleLegal utilizes AWS Key Management Service (KMS) to securely create and manage keys and control the use of encryption across its cloud-based environment.	Inspected the AWS dashboard to verify whether KMS was used to create and manage encryption keys across SimpleLegal's cloud-based environment.	No exceptions noted.
CC6.1.4	SimpleLegal utilizes Virtual Private Clouds (VPCs) and sub-networks (subnets) to achieve network segmentation in its AWS cloud-based environment.	Inspected the AWS dashboard to verify whether VPCs and subnets were utilized to achieve network segmentation within the AWS cloud-based environment.	No exceptions noted.
CC6.1.5	SimpleLegal utilizes the AWS Identity and Access Management (IAM) console to securely manage access to AWS services and resources. IAM enables the Company to create and manage AWS users/groups and define use permissions that allow and deny access to AWS resources.	Inspected the AWS dashboard to verify whether IAM tools were used to securely manage access to services and resources in AWS.	No exceptions noted.
CC6.1.6	SimpleLegal encrypts data at rest through server-side encryption (SSE) using AES-256.	Inspected the AWS database configurations to verify whether production data was encrypted at rest using AES-256.	No exceptions noted.
CC6.1.7	SimpleLegal maintains active SHA-256 encryption certificates for its web application to ensure secure connections for its users.	Inspected SimpleLegal's web application login page to verify whether an active SHA-256 encryption certificate was in place.	No exceptions noted.
CC6.1.8	SimpleLegal encrypts all employee and contractor workstations with full disk encryption.	Inspected the Jamf Pro dashboard to verify whether all employee and contractor workstations had full disk encryption enabled.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC6.1.9	Administrative and privileged access rights are restricted to authorized personnel using a role-based access scheme, in accordance with the principle of least privilege.	Inspected administrative access rights for SimpleLegal's critical applications and cloud infrastructure to verify whether privileged access was limited to authorized personnel using a role-based access scheme, in accordance with the principle of least privilege.	No exceptions noted.
CC6.2: Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CC6.2.1	An authorized system administrator approves access to SimpleLegal systems and applications for newly hired personnel as well as access change requests.	For all new hires during the period, inspected onboarding tickets to verify whether access rights to SimpleLegal's systems and applications were approved by a system administrator and were appropriate based on each of the new hires' roles. For a selection of role changes during the period, inspected IT tickets to verify whether access rights to SimpleLegal's systems and applications were approved by a system administrator and were appropriate.	No exceptions noted.
CC6.2.2	System access is removed within 48 hours upon employee or contractor termination.	For a selection of terminated personnel during the period, inspected offboarding tickets to verify whether system access was removed within 48 hours of termination.	No exceptions noted.
CC6.2.3	On a quarterly basis, management reviews access rights for all SimpleLegal personnel to ensure that system access is appropriate. Any access rights that are no longer needed are removed following this review.	For a selection of quarters, inspected the account audit reports to verify whether comprehensive user access reviews were conducted by management during the period and that access rights were modified as needed, based on the review.	No exceptions noted.
CC6.3: The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CC6.3.1	An authorized system administrator approves access to SimpleLegal systems and applications for newly hired personnel as well as access change requests.	For all new hires during the period, inspected onboarding tickets to verify whether access rights to SimpleLegal's systems and applications were approved by a system administrator and were appropriate based on each of the new hires' roles. For a selection of role changes during the period, inspected IT tickets to verify whether access rights to SimpleLegal's systems and applications were approved by a system administrator and were appropriate.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC6.3.2	System access is removed within 48 hours upon employee or contractor termination.	For a selection of terminated personnel during the period, inspected offboarding tickets to verify whether system access was removed within 48 hours of termination.	No exceptions noted.
CC6.3.3	On a quarterly basis, management reviews access rights for all SimpleLegal personnel to ensure that system access is appropriate. Any access rights that are no longer needed are removed following this review.	For a selection of quarters, inspected the account audit reports to verify whether comprehensive user access reviews were conducted by management during the period and that access rights were modified as needed, based on the review.	No exceptions noted.
CC6.3.4	SimpleLegal maintains remote-wipe software on all Company workstations.	Inspected the Jamf Pro dashboard to verify whether remote-wipe software for workstations had been deployed across the organization.	No exceptions noted.
CC6.4: The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.			
CC6.4.1	Onit maintains a Physical Security Policy that outlines requirements around maintaining security of Onit offices and IT equipment.	Inspected the Physical Security Policy to verify whether it outlined requirements around maintaining security of Onit offices and IT equipment.	No exceptions noted.
CC6.4.2	The entrance to Onit's office is locked and a keycard/fob is required to gain entry.	Inspected images of the Onit office in Houston to verify whether the entrance was locked, and a keycard/fob was required to gain entry.	No exceptions noted.
CC6.4.3	Onit utilizes video surveillance cameras that provide 24/7 video streaming, recoding, and motion detection.	Inspected images of the Onit office in Houston to verify whether Onit utilized cameras to provide 24/7 surveillance of the office.	No exceptions noted.
CC6.4.4	Onit maintains an office shred bin for the disposal of sensitive hardcopy materials.	Inspected images of the Onit office in Houston to verify whether the Onit office had a shred bin to securely dispose of sensitive hardcopy materials.	No exceptions noted.
SimpleLegal uses AWS to provide cloud computing and data center hosting services. Please reference <i>Complementary Subservice Organization Controls (CSOCs)</i> in Section III for additional controls that are to be implemented by the subservice organization.			
CC6.5: The entity discontinues logical and physical protections over physical assets only after the ability to read and recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.			
CC6.5.1	SimpleLegal maintains a Record Retention Policy that outlines how long various types of information are to be retained by the Company. Obsolete information systems and databases, as well as electronic and hard-copy files, are disposed of in accordance with this policy.	Inspected the Record Retention Policy to verify whether it outlined the requirements for disposing of various types of information at SimpleLegal.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC6.5.2	Prior to disposing of obsolete workstations or removable media, the SVP, Business Operations & Integrations or the Director, Information Technology ensure that all physical devices are sanitized to remove any confidential information.	Inspected images of the Onit office in Houston to verify whether workstations and removable media were stored in a secure location prior to reuse or disposal. Per inspection of the asset inventory and inquiry of management, noted that there were no disposals of obsolete workstations or removable media during the period. Therefore, further testing was not applicable.	No exceptions noted.
CC6.6: The entity implements logical access security measures to protect against threats from sources outside its system boundaries.			
CC6.6.1	Firewall rules are configured to restrict network traffic to approved ports, protocols, and sources.	Inspected the AWS security group configurations to verify whether network traffic was restricted to approved ports, protocols, and sources.	No exceptions noted.
CC6.6.2	SimpleLegal utilizes a Web Application Firewall (WAF) to protect the web application from web-based threats.	Inspected the Cloudflare dashboard to verify whether a WAF was utilized to protect the application from web-based threats.	No exceptions noted.
CC6.7: The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes and protects it during transmission, movement, or removal to meet the entity's objectives.			
CC6.7.1	SimpleLegal utilizes AWS Systems Manager to enable secure remote access to cloud resources for its employees and contractors.	Inspected the AWS dashboard to verify whether Systems Manager was enabled to ensure secure remote access to cloud resources for SimpleLegal's employees and contractors.	No exceptions noted.
CC6.7.2	Data in transit is encrypted using Transport Layer Security (TLS) 1.2 or higher.	Inspected the server configuration for the web application to verify whether it only accepted connections using TLS 1.2 or above.	No exceptions noted.
CC6.7.3	A centralized mobile device management solution has been deployed to Company-owned workstations to enforce built-in security controls.	Inspected the Jamf Pro dashboard to verify whether a centralized mobile device management solution had been deployed to Company-owned workstations to enforce built-in security controls.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC6.8: The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.			
CC6.8.1	SimpleLegal utilizes an endpoint protection tool to monitor employee devices and ensure that endpoint protection, including antivirus/anti-malware, is enabled to prevent the introduction of unauthorized or malicious software. The endpoint protection system has alerts, logs, and reporting functionality to analyze and inform the Company of potential threats.	Inspected the Sophos dashboard to verify whether endpoint protection software was deployed across the organization to prevent and detect unauthorized or malicious software such as viruses, malware, and ransomware. Inspected the Sophos dashboard to verify whether alerts, logs, and reports were generated when potential threats were detected by the endpoint protection software.	No exceptions noted.
CC6.8.2	SimpleLegal configures its email security policies to protect the organization from phishing, malware, and spam. Emails that have been quarantined are accessible to administrators for further review.	Inspected the Mimecast dashboard to verify whether SimpleLegal configured its email security policies to protect the organization from phishing, malware, and spam and that any emails that have been quarantined are only accessible to administrators.	No exceptions noted.
System Operations			
CC7.1: To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities and (2) susceptibilities to newly discovered vulnerabilities.			
CC7.1.1	SimpleLegal maintains baseline configurations for its information systems and system components to reflect the current enterprise architecture.	Inspected the System Hardening Guidelines and the Jamf Pro configuration profiles to verify whether SimpleLegal maintained baseline configurations for its information systems and system components.	No exceptions noted.
CC7.1.2	SimpleLegal has implemented a vulnerability management program to detect and remediate system vulnerabilities in software packages used in the Company's infrastructure. System patching is performed on a periodic basis by the infrastructure team for proper vulnerability mitigation.	For a selection of months during the period, inspected the Probely vulnerability scanning reports to verify whether SimpleLegal had implemented a vulnerability management program to detect and remediate system vulnerabilities in software packages. Per inspection of the Probely vulnerability scanning reports, noted that there were no vulnerabilities that required patching. Therefore, further testing was not applicable.	No exceptions noted.
CC7.1.3	SimpleLegal uses intrusion detection systems that continuously monitor for malicious activity and unauthorized behavior related to AWS accounts, workloads, and data.	Inspected the GuardDuty and CrowdStrike intrusion detection systems to verify whether they were implemented to monitor for malicious activity and unauthorized behavior related to AWS accounts, workloads, and data.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC7.1.4	A log management tool is utilized to identify trends that may have a potential impact on the Company's ability to achieve its security objectives.	Inspected the Elastic dashboard to verify whether a log management tool was utilized to identify trends that may have a potential impact on the Company's ability to achieve its security objectives.	No exceptions noted.
CC7.2: The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.			
CC7.2.1	SimpleLegal maintains updated detection policies, procedures, and tools to identify anomalies or unusual activity on information systems. Potential security incidents are filtered and analyzed based on established detection measures.	Inspected the Incident Reporting and Response Policy to verify whether it adequately documented incident detection processes and management of potential incidents. Inspected the following monitoring tools to verify whether they were adequately leveraged to identify anomalies or unusual activity on information systems: • Web application penetration testing • Intrusion detection systems • Vulnerability scanning • Phishing simulations	No exceptions noted.
CC7.2.2	Detection tools are periodically analyzed by management for effectiveness and remedial action is taken when necessary.	For a selection of months, inspected executive leadership meeting invitations and agendas to verify whether the security team was included as attendees.	No exceptions noted.
SimpleLegal uses AWS to provide cloud computing and data center hosting services. Please reference <i>Complementary Subservice Organization Controls (CSOCs)</i> in Section III for additional controls that are to be implemented by the subservice organization.			
CC7.3: The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.			
CC7.3.1	Incidents related to security are logged, tracked, and communicated to affected parties. Incidents are resolved in a timely manner in accordance with the formal incident management process.	Inspected the incident tracker to verify whether it was utilized for logging potential incidents. For all incidents that occurred during the period, inspected incident tickets to verify whether SimpleLegal followed the incident response program.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC7.4: The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.			
CC7.4.1	SimpleLegal maintains an updated incident response program that defines procedures for containing, mitigating, and ending the threats posed by security incidents, as well as restoring operations and communicating security incidents and actions taken to affected parties.	Inspected the Incident Reporting and Response Policy to verify whether it provided comprehensive requirements and guidelines on how to effectively respond to potential security incidents and make necessary changes to mitigate the risk of future events.	No exceptions noted.
CC7.4.2	SimpleLegal follows the incident response program by understanding the nature of the incident, determining a containment strategy, remediating identified vulnerabilities, and communicating remediation activities to appropriate internal and external parties.	Inspected the Incident Reporting and Response Policy to verify whether it outlined requirements for understanding the nature of the incident, determining a containment strategy, remediating identified vulnerabilities, and communicating remediation activities. For all incidents that occurred during the period, inspected the incident tickets to verify whether SimpleLegal followed the incident response program.	No exceptions noted.
CC7.5: The entity identifies, develops, and implements activities to recover from identified security incidents.			
CC7.5.1	SimpleLegal follows the Incident Response Plan to restore the affected environment to full operation by rebuilding systems, updating software, installing patches, and/or changing configurations, as needed.	Inspected the Incident Reporting and Response Policy to verify whether it outlined processes for restoring the affected environment. For all incidents that occurred during the period, inspected the incident tickets to verify whether SimpleLegal restored the affected environments as applicable.	No exceptions noted.
CC7.5.2	Information about the nature of the incident, recovery actions taken, and activities required for the prevention of future security events are communicated to appropriate internal and external parties.	Inspected the Incident Reporting and Response Policy to verify whether it outlined processes for communicating information to relevant parties. For all incidents that occurred during the period, inspected the incident tickets to verify whether the log included information about the nature of the incident, recovery actions taken, and activities implemented for the prevention of future security events.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC7.5.3	After an incident has been resolved and appropriate parties have been notified, a postmortem that includes a root cause analysis and lessons learned is completed. Architectural and/or procedural changes are implemented, when possible, to prevent and detect recurrences of similar incidents. This includes conducting additional training to educate personnel on how to prevent future incidents.	Inspected the Incident Reporting and Response Policy to verify whether it outlined processes for performing an incident postmortem. For all incidents that occurred during the period, inspected the incident tickets to verify whether the appropriate parties had been notified, a postmortem with a root cause analysis was performed, and a lessons learned evaluation was completed.	No exceptions noted.
Change Management			
CC8.1: The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CC8.1.1	SimpleLegal maintains updated change management and software development policies that govern the systems development lifecycle (SDLC), including (1) authorizing system changes prior to development; (2) designing and developing system changes; (3) documenting and tracking changes prior to implementation; (4) testing and approving system changes; (5) deploying changes to production; (6) evaluating the changes against their objectives; and (7) modifying infrastructure, data, software, and procedures to remediate identified incidents.	Inspected the Change Management Policies to verify whether they adequately documented SDLC processes and controls, including requirements around maintaining information security during software development.	No exceptions noted.
CC8.1.2	SimpleLegal uses a version control system to manage source code, documentation, release labeling, and other change management tasks. Access to the system must be approved by a system administrator.	Inspected the GitLab dashboard to verify whether SimpleLegal utilized a version control system to manage source code, documentation, release labeling, and other change management tasks. For all new hires during the period, inspected onboarding tickets to verify whether access rights to SimpleLegal's systems and applications were approved by a system administrator and were appropriate based on each of the new hires' roles.	No exceptions noted.
CC8.1.3	Developers are unable to deploy changes to production without independent code review and approval. All deployments are logged, including who deployed the change and at what time it was deployed.	Inspected the GitLab configurations to verify whether merge requests required at least one independent code review and approval prior to deployment to the production environment.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC8.1.4	SimpleLegal maintains separate test and production environments for software development.	Inspected the AWS dashboard to verify whether SimpleLegal maintained separate test and production environments for software development.	No exceptions noted.
CC8.1.5	Changes to the production environment are communicated to affected internal and external stakeholders.	Inspected external release notes and internal product change communications to verify whether changes to the production environment were communicated to internal and external users.	No exceptions noted.
Risk Mitigation			
CC9.1: The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.			
CC9.1.1	SimpleLegal maintains insurance to mitigate the financial impact of business disruptions, including cyber incidents.	Inspected the insurance policies for SimpleLegal to verify whether they included coverage against major financial risks to the business, including cyber incidents.	No exceptions noted.
CC9.1.2	SimpleLegal maintains updated business continuity and disaster recovery plans that guide the organization in how to respond to and recover from disruptions in networks, systems, and internal operations. The plans are tested on an annual basis.	Inspected the Business Continuity and Disaster Recovery Plans to verify whether they provided comprehensive instructions on how to respond and recover from disruptions in networks, systems, and internal operations. Inspected the disaster recovery exercise report to verify whether a test of the Business Continuity and Disaster Recovery plans had been conducted during the period.	No exceptions noted.
CC9.2: The entity assesses and manages risks associated with vendors and business partners.			
CC9.2.1	SimpleLegal maintains an updated Vendor Management Policy to monitor and ensure service levels and ongoing compliance of existing vendors. The policy outlines roles, responsibilities, and communication protocols around managing vendor relationships and exception handling.	Inspected the Vendor Management Policy to verify whether it adequately documented requirements and guidelines for conducting vendor due diligence reviews and risk assessments.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
CC9.2.2	SimpleLegal conducts comprehensive vendor due diligence prior to onboarding new high-risk vendors, as well as on an annual basis for existing high-risk vendors. This includes performing a vendor risk assessment and reviewing the SOC 2 reports, SOC 3 reports, ISO 27001 certifications and/or responses to information security questionnaires.	For the one new vendor onboarded during the period, inspected the completed security review documentation and collected report to verify whether SimpleLegal had reviewed SOC 2 reports, SOC 3 reports, ISO 27001 certifications, and/or responses to information security questionnaires prior to onboarding. For all existing high-risk vendors, inspected the completed security review documentation and collected reports to verify whether SimpleLegal had reviewed SOC 2 reports, SOC 3 reports, ISO 27001 certifications, and/or responses to information security questionnaires.	No exceptions noted.

AVAILABILITY

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
A1.1: The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.			
A1.1.1	SimpleLegal measures current usage of its system components to establish a baseline for capacity management and to identify peak use times. The risk of impaired availability due to capacity constraints is analyzed and mitigated on an ongoing basis.	Inspected the AWS dashboard to verify whether SimpleLegal measures current usage of its system components to establish a baseline for capacity management and to identify peak use times.	No exceptions noted.
A1.1.2	Load Balancers are utilized in AWS to automatically distribute network traffic and improve application scalability.	Inspected the AWS dashboard to verify whether Load Balancers were utilized to automatically distribute network traffic and improve application scalability.	No exceptions noted.
A1.1.3	AWS is configured to automatically scale system capacity to maintain steady, predictable performance.	Inspected the AWS dashboard to verify whether Auto-Scaling groups were established to maintain steady, predictable performance.	No exceptions noted.
A1.1.4	SimpleLegal automatically distributes incoming application traffic across multiple targets and virtual appliances in multiple availability zones.	Inspected the AWS dashboard to verify whether multiple availability zones were established to distribute application traffic.	No exceptions noted.
A1.2: The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.			
A1.2.1	AWS S3 buckets containing user data have versioning enabled.	Inspected the AWS dashboard to verify whether buckets containing user data had versioning enabled.	No exceptions noted.
A1.2.2	Data backups are performed daily and retained for a period of at least 30 days across multiple availability zones.	Inspected the AWS backup configurations to verify whether SimpleLegal performed data backups daily and retained them for at least 30 days across multiple availability zones.	No exceptions noted.
SimpleLegal uses AWS to provide cloud computing and data center hosting services. Please reference <i>Complementary Subservice Organization Controls (CSOCs)</i> in Section III for additional controls that are to be implemented by the subservice organization.			

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
A1.3: The entity tests recovery plan procedures supporting system recovery to meet its objectives.			
A1.3.1	SimpleLegal maintains updated business continuity and disaster recovery plans that guide the organization in how to respond to and recover from disruptions in networks, systems, and internal operations. The plans are tested on an annual basis.	Inspected the Business Continuity and Disaster Recovery Plans to verify whether they provided comprehensive instructions on how to respond and recover from disruptions in networks, systems, and internal operations. Inspected the disaster recovery exercise report to verify whether a test of the Business Continuity and Disaster Recovery plans had been conducted during the period.	No exceptions noted.
A1.3.2	SimpleLegal tests the integrity and completeness of backups on at least an annual basis.	Inspected the continuity plan checklist to verify whether SimpleLegal tested the integrity and completeness of backups on at least an annual basis.	No exceptions noted.

CONFIDENTIALITY

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
C1.1: The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.			
C1.1.1	SimpleLegal has policies and procedures in place that govern how confidential data is secured and restricted to authorized personnel.	Inspected the Information Classification and Information Disposal policies to verify whether SimpleLegal had policies and procedures that governed how confidential data is secured and restricted to authorized personnel.	No exceptions noted.
C1.1.2	Prior to joining SimpleLegal, all employees and contractors are required to sign confidentiality agreements.	For all new hires during the period, inspected the signed contract to verify whether each individual was required to sign a confidentiality agreement prior to joining the Company.	For 1 of 4 selected new hires, the confidentiality agreement was signed after joining SimpleLegal. Exception noted.
C1.1.3	Business Associate Agreements are signed by SimpleLegal's business partners prior to establishing a formalized relationship.	Per inspection of the Business Associate Agreement dashboard, there were no new business partners onboarded during the period. Therefore, testing was not applicable.	
C1.1.4	SimpleLegal has Terms of Service in place with customers which demonstrates the Company's security commitments related to confidential information.	Inspected the SimpleLegal Terms of Service to verify whether it demonstrated the Company's security and confidentiality commitments.	No exceptions noted.
C1.2: The entity disposes of confidential information to meet the entity's objectives related to confidentiality.			
C1.2.1	SimpleLegal has policies and procedures in place that govern how confidential information is securely deleted.	Inspected the Information Disposal Policy to verify whether it outlined the requirements for disposing of various types of information at SimpleLegal.	No exceptions noted.
C1.2.2	Customer information is deleted in a timely manner, in accordance with contractual requirements.	For a selection of churned customers during the period, inspected offboarding tickets to verify whether SimpleLegal deleted customer information in a timely manner, in accordance with contractual requirements.	No exceptions noted.

PRIVACY

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Privacy Criteria Related to Notice and Communication of Objectives Related to Privacy			
P1.1: The entity provides notice to data subjects about its privacy practices to meet the entity's objectives related to privacy. The notice is updated and communicated to data subjects in a timely manner for changes to the entity's privacy practices, including changes in the use of personal information, to meet the entity's objectives related to privacy.			
This criterion is not applicable to data processors.			
Privacy Criteria Related to Choice and Consent			
P2.1: The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice. Explicit consent for the collection, use, retention, disclosure, and disposal of personal information is obtained from data subjects or other authorized persons, if required. Such consent is obtained only for the intended purpose of the information to meet the entity's objectives related to privacy. The entity's basis for determining implicit consent for the collection, use, retention, disclosure, and disposal of personal information is documented.			
This criterion is not applicable to data processors.			
Privacy Criteria Related to Collection			
P3.1: Personal information is collected consistent with the entity's objectives related to privacy.			
P3.1.1	SimpleLegal limits the collection of personal information only to what is necessary, in accordance with the Privacy Policy.	Inspected the SimpleLegal Terms of Service and Privacy Policy to verify whether personal information collected as part of SimpleLegal's services was consistent with the terms of the agreement.	No exceptions noted.
P3.1.2	SimpleLegal reviews the methods of collecting information before they are implemented to confirm that personal information is obtained (a) fairly, without intimidation or deception, and (b) lawfully, adhering to all relevant rules or law, whether derived from statute or common law, relating to the collection of personal information.	Inspected the organizational chart and inquired of the General Counsel to verify whether a legal and compliance team is in place to evaluate the methods by which personal information is collected.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P3.1.3	SimpleLegal confirms that third parties from whom personal information is collected are reliable sources that collect information fairly and lawfully.	For all third-party sub-processors, inspected the signed agreements to verify whether SimpleLegal confirmed that third parties from whom personal information is collected were reliable sources and that they collect information fairly and lawfully.	No exceptions noted.
P3.1.4	Data subjects are informed if SimpleLegal develops or acquires additional information about them for its use.	Inspected the Privacy Policy to verify whether it provided an objective description of the personal information that SimpleLegal collects.	No exceptions noted.
P3.2: For information requiring explicit consent, the entity communicates the need for such consent, as well as the consequences of a failure to provide consent for the request for personal information, and obtains the consent prior to the collection of the information to meet the entity's objectives related to privacy.			
This criterion is not applicable to data processors.			
Privacy Criteria Related to Use, Retention, and Disposal			
P4.1: The entity limits the use of personal information to the purposes identified in the entity's objectives related to privacy.			
P4.1.1	SimpleLegal limits the use of personal information only for the intended purposes for which it was collected and only when it has lawful basis to collect and process such data.	Inspected the SimpleLegal website to verify whether the defined limitations on the use and retention of personal information were in line with the Privacy Policy. Inspected the organizational chart and inquired of the General Counsel to verify whether a legal and compliance team is in place to evaluate the methods by which personal information is collected.	No exceptions noted.
P4.2: The entity retains personal information consistent with the entity's objectives related to privacy.			
P4.2.1	SimpleLegal retains personal information for no longer than necessary to fulfill the stated purposes unless a law or regulation specifically requires otherwise.	Inspected the SimpleLegal Privacy Policy to verify whether it documented data subjects' right to the erasure of personal information. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P4.2.2	SimpleLegal maintains policies and procedures to protect personal information from erasure during the specified retention period of the information.	Inspected the Records Retention and Information Disposal policies to verify whether they outlined how data was to be protected from erasure during the specified retention period.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P4.3: The entity securely disposes of personal information to meet the entity's objectives related to privacy.			
P4.3.1	SimpleLegal captures requests for the deletion of personal information and identifies and flags the information for destruction to support the achievement of its objectives related to privacy.	Inspected the SimpleLegal Privacy Policy to verify whether it documented data subjects' right to the erasure of personal information. Inspected procedure documentation for processing privacy requests to verify whether specific data and data locations were defined for processing deletion requests. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P4.3.2	Personal information no longer retained is disposed of by SimpleLegal in a manner that prevents loss, theft, misuse, or unauthorized access.	Inspected the Records Retention and Information Disposal policies to verify whether they documented requirements pertaining to the secure disposal of personal information identified for destruction. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P4.3.3	SimpleLegal maintains policies and procedures to erase or otherwise destroy personal information that has been identified for destruction.	Inspected the Records Retention and Information Disposal policies to verify whether they documented requirements pertaining to the secure disposal of personal information identified for destruction.	No exceptions noted.
Privacy Criteria Related to Access			
P5.1: The entity grants identified and authenticated data subjects the ability to access their stored personal information for review and, upon request, provides physical or electronic copies of that information to data subjects to meet the entity's objectives related to privacy. If access is denied, data subjects are informed of the denial and reason for such denial, as required, to meet the entity's objectives related to privacy.			
P5.1.1	SimpleLegal maintains a process to respond to data subject requests received from data controllers in accordance with privacy objectives. This process includes authentication of the request and responding within a reasonable time.	Inspected the Privacy Policy to verify whether it included contact information for data subject requests. Inspected procedure documentation for processing privacy requests to verify whether it included requirements to authenticate the identity of the data subject making the request and respond within a reasonable time period.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P5.1.2	SimpleLegal enables data subjects to determine whether personal information about them is maintained.	Inspected the Privacy Policy to verify whether it included contact information for data subject requests. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P5.1.3	SimpleLegal authenticates the identify of data subjects who request access to their personal information before giving them access to that information.	Inspected procedure documentation for processing privacy requests to verify whether it included a requirement to authenticate the identity of the data subject making the request. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P5.1.4	SimpleLegal provides personal information to data subjects in an understandable form, in a reasonable timeframe, and at a reasonable cost, if any.	Inspected procedure documentation for processing privacy requests to verify whether it included requirements to provide personal information to data subjects in an understandable form, in a reasonable timeframe, and at a reasonable cost, if necessary. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.
P5.2: The entity corrects, amends, or appends personal information based on information provided by data subjects and communicates such information to third parties, as committed or required, to meet the entity's objectives related to privacy. If a request for correction is denied, data subjects are informed of the denial and reason for such denial to meet the entity's objectives related to privacy.			
P5.2.1	SimpleLegal has a process to respond to data subjects' update requests, including enabling them to correct their personal information, in accordance with SimpleLegal's objectives related to privacy.	Inspected procedure documentation for processing privacy requests to verify whether it included requirements to provide personal information to data subjects in an understandable form, in a reasonable timeframe, and at a reasonable cost, if necessary. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Privacy Criteria Related to Disclosure and Notification			
P6.1: The entity discloses personal information to third parties with the explicit consent of data subjects, and such consent is obtained prior to disclosure to meet the entity's objectives related to privacy.			
P6.1.1	SimpleLegal discloses personal information only to clients and third parties who have agreements in place to protect personal information in a manner consistent with the relevant aspects of SimpleLegal's privacy policy.	Inspected the SimpleLegal Terms of Service to verify whether terms for third party disclosure of personal information were defined. For all third-party sub-processors that have access to personal information, inspected contractual agreements to verify whether they limited the disclosure of personal information with third parties.	No exceptions noted.
P6.1.2	SimpleLegal discloses personal information to clients and third parties only for the purposes for which it was collected unless a law or regulation specifically requires otherwise.	Inspected the SimpleLegal Privacy Policy to verify whether it defined limitations on the use and retention of personal information. Inspected the organizational chart and inquired of the General Counsel to verify whether a legal and compliance team is in place to evaluate the methods by which personal information is collected.	No exceptions noted.
P6.2: The entity creates and retains a complete, accurate, and timely record of authorized disclosures of personal information to meet the entity's objectives related to privacy.			
P6.2.1	SimpleLegal creates and maintains a record of authorized disclosures of personal information that is complete, accurate, and timely.	Inspected the SimpleLegal Privacy Policy to verify whether data subjects were informed about how SimpleLegal shares their information. Inspected the sub-processor inventory to verify whether it defined a list of approved vendors with whom personal information is shared.	No exceptions noted.
P6.3: The entity creates and retains a complete, accurate, and timely record of detected or reported unauthorized disclosures (including breaches) of personal information to meet the entity's objectives related to privacy.			
P6.3.1	SimpleLegal creates and maintains a record of detected or reported unauthorized disclosures of personal information that is complete, accurate, and timely.	For all incidents that occurred during the period, inspected the incident ticket to verify whether SimpleLegal created and maintained a record of detected or reported unauthorized disclosures of personal information that is complete, accurate, and timely.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P6.4: The entity obtains privacy commitments from vendors and other third parties who have access to personal information to meet the entity's objectives related to privacy. The entity assesses those parties' compliance on a periodic and as-needed basis and takes corrective action, if necessary.			
P6.4.1	SimpleLegal maintains a process for obtaining commitments from vendors and other third parties to report to SimpleLegal actual or suspected unauthorized disclosures of personal information.	For all third-party sub-processors, inspected signed agreements to verify whether SimpleLegal obtained commitments from third parties to report unauthorized disclosures of personal information.	No exceptions noted.
P6.4.2	SimpleLegal takes remedial action in response to misuse of personal information by a third party to whom SimpleLegal has transferred such information.	For all incidents that occurred during the period, inspected the incident ticket to verify whether SimpleLegal took remedial action in response to misuse of personal information by a third party to whom SimpleLegal has transferred such information.	No exceptions noted.
P6.4.3	SimpleLegal has procedures in place to evaluate whether third parties have effective controls to meet the terms of privacy agreements, instructions, or requirements.	For all existing high-risk vendors, inspected the completed security review documentation and collected reports to verify whether SimpleLegal had reviewed SOC 2 reports, SOC 3 reports, ISO 27001 certifications, and/or responses to information security questionnaires. Per inspection of the vendor list and inquiry of management, noted there were no new vendors onboarded during the period. Therefore, further testing was not applicable.	No exceptions noted.
P6.5: The entity obtains commitments from vendors and other third parties with access to personal information to notify the entity in the event of actual or suspected unauthorized disclosures of personal information. Such notifications are reported to appropriate personnel and acted on in accordance with established incident response procedures to meet the entity's objectives related to privacy.			
P6.5.1	SimpleLegal maintains a process for obtaining commitments from vendors and other third parties to report to SimpleLegal actual or suspected unauthorized disclosures of personal information.	For all third-party sub-processors, inspected the signed agreements to verify whether they included commitments to inform SimpleLegal of actual or suspected unauthorized disclosures.	No exceptions noted.
P6.5.2	SimpleLegal takes remedial action in response to misuse of personal information by a third party to whom SimpleLegal has transferred such information.	For all third-party sub-processors, inspected the contractual agreements to verify whether they included commitments to inform SimpleLegal of actual or suspected unauthorized disclosures. For all incidents that occurred during the period, inspected the incident ticket to verify whether SimpleLegal took remedial action in response to misuse of personal information by a third party to whom SimpleLegal has transferred such information.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P6.6: The entity provides notification of breaches and incidents to affected data subjects, regulators, and others to meet the entity's objectives related to privacy.			
P6.6.1	SimpleLegal maintains a process for determining whether notification of a privacy breach is required, including the method to be used, the timeline, and the identification of the recipients of such notifications.	Inspected the SimpleLegal Privacy Policy and Breach Notification Policy to verify whether the Company maintained a process for determining whether privacy breach notifications were required.	No exceptions noted.
P6.6.2	SimpleLegal maintains a process for providing notice of breaches and incidents to affected data subjects, regulators, and others to support the achievement of its objectives related to privacy.	Inspected the SimpleLegal Privacy Policy and Breach Notification Policy to verify whether the Company maintained a process for providing breach notifications and incidents to affected parties.	No exceptions noted.
P6.7: The entity provides data subjects with an accounting of the personal information held and disclosure of the data subjects' personal information, upon the data subjects' request, to meet the entity's objectives related to privacy.			
P6.7.1	SimpleLegal identifies the types of personal information and the related processes, systems, and third parties involved in the handling of such information.	For all third-party sub-processors, inspected the contractual agreements to verify whether commitments were obtained to notify SimpleLegal in the event of an actual or suspected unauthorized disclosure of personal information. Inspected the SimpleLegal Privacy Policy to verify whether it provided an objective description of the personal information that SimpleLegal has collected.	No exceptions noted.
P6.7.2	Requests for an accounting of personal information held and disclosures of the data subjects' personal information are captured by SimpleLegal, and information related to the requests is identified and communicated to data subjects to support the achievement of SimpleLegal's privacy objectives.	Inspected procedure documentation for processing privacy requests to verify whether specific data and data locations were defined for processing data subject requests. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
Privacy Criteria Related to Quality			
P7.1: The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet the entity's objectives related to privacy.			
P7.1.1	SimpleLegal ensures that personal information is accurate and complete for the purposes for which it is to be used.	Inspected the SimpleLegal Privacy Policy to verify whether it defined limitations on the use and retention of personal information. Inspected the organizational chart and inquired of the General Counsel to verify whether a legal and compliance team is in place to evaluate the methods by which personal information is collected.	No exceptions noted.
P7.1.2	SimpleLegal ensures that personal information is relevant to the purposes for which it is to be used.	Inspected the SimpleLegal Privacy Policy to verify whether it defined limitations on the use and retention of personal information. Inspected the organizational chart and inquired of the General Counsel to verify whether a legal and compliance team is in place to evaluate the methods by which personal information is collected.	No exceptions noted.
Privacy Criteria Related to Monitoring and Enforcement			
P8.1: The entity implements a process for receiving, addressing, resolving, and communicating the resolution of inquiries, complaints, and disputes from data subjects and others and periodically monitors compliance to meet the entity's objectives related to privacy. Corrections and other necessary actions related to identified deficiencies are made or taken in a timely manner.			
P8.1.1	SimpleLegal informs data subjects about how to contact them with inquiries, complaints, and disputes.	Inspected the SimpleLegal website to verify whether contact information was available for general inquiries, customer support, partnerships, and public relations. Inspected a test submission to the SimpleLegal support channel to verify whether it was actively monitored and managed by the support team.	No exceptions noted.
P8.1.2	SimpleLegal maintains a process to address inquiries, complaints, and disputes.	Inspected procedure documentation for processing privacy requests to verify whether SimpleLegal had a process in place to address inquiries, complaints, and disputes.	No exceptions noted.

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
P8.1.3	SimpleLegal addresses each complaint, and the resolution is documented and communicated to the individual.	Inspected procedure documentation for processing privacy requests to verify whether specific data and data locations were defined for processing data subject requests. Per inspection of the Legal Services Request dashboard, noted there were no data subject requests during the period. Therefore, further testing was not applicable.	No exceptions noted.



SECTION V

OTHER INFORMATION PROVIDED BY SIMPLELEGAL

Management's Response to Testing Exception

Control #	Control Activity Specified by SimpleLegal	Boulay's Test of Controls	Test Results
C1.1: The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.			
C1.1.2	Prior to joining SimpleLegal, all employees and contractors are required to sign confidentiality agreements.	For all new hires during the period, inspected the signed contract to verify whether each individual was required to sign a confidentiality agreement prior to joining the Company.	For 1 of 4 selected new hires, the confidentiality agreement was signed after joining SimpleLegal. Exception noted.
Management's Response:	SimpleLegal's onboarding process includes the confidentiality agreement as part of the standard workflow. While these agreements are typically signed before the start date, one selected employee completed theirs two days after starting. To strengthen compliance, we will work with our HR team to reinforce the importance that confidentiality agreements are signed before the first day and ensure hiring managers and HR personnel clearly communicate this requirement.		